VolkanBank



📄 Doküman 1 – Kullanıcı Listesi

UsernameRoleLast Loginahmet.yilmazAdmin2 gün öncemehmet.demirDeveloper1 gün önceselin.kayaAuditor7 gün önceburak.cetinAdmin412 gün önceemre.ozkanDBA3 gün önceayse.turanSupport2 gün önce

📄 Doküman 2 – İşten Ayrılan Personel

EmployeeTermination DateBurak Çetin14 ay önce

📄 Doküman 3 – Password Policy

KontrolDurumMinimum Length8Complexity RequirementOptionalPassword ExpiryDisabledMFAOptionalAccount LockoutDisabled

📄 Doküman 4 – Password Database Extract

UsernameHashahmet.yilmaz5f4dcc3b5aa765d61d8327deb882cf99mehmet.demire10adc3949ba59abbe56e057f20f883eselin.kaya25d55ad283aa400af464c76d713c07adburak.cetin81dc9bdb52d04dc20036dbd8313ed055emre.ozkan21232f297a57a5a743894a0e4a801fc3ayse.turan098f6bcd4621d373cade4e832627b4f6

📄 Doküman 5 – Access Review Procedure

"All privileged and business user accounts shall be reviewed annually."

Son erişim gözden geçirme tarihi:

📅 **18 ay önce**

📄 Doküman 6 – Shared Accounts

Accountadminsharedsupportshared

Açıklama:

"Operasyonel kolaylık amacıyla ekip üyeleri ortak hesap kullanabilmektedir."

📝 Görevler

Soru 1

🔍 En az **5 adet denetim bulgusu** tespit ediniz.

Her bulgu için aşağıdakileri belirtiniz:

- Risk
- Etki
- Öneri

Soru 2

Yönetimin aşağıdaki iddiasına katılıyor musunuz?

"Parolalarımız güçlüdür."

Neden?

Detaylı olarak açıklayınız.

Soru 3

Hash değerlerini inceleyiniz.

Aşağıdaki sorulara cevap veriniz:

- Kullanılan hash algoritması nedir?
- Günümüzde güvenli kabul edilir mi?
- Herhangi bir saldırı riski bulunuyor mu?
- Hash değerleri size kullanıcı parolaları hakkında bir fikir veriyor mu?

Araştırarak açıklayınız.

Soru 4

Tespit ettiğiniz bulgular arasından:

🚨 En kritik bulguyu seçiniz.

Aşağıdaki başlıklarda açıklama yapınız:

- Risk
- İş Etkisi
- Olası Senaryo
- Kuruma Potansiyel Zarar

Soru 5

👔 Yönetim Kurulu'na gönderilecek şekilde;

Maksimum **5 cümlelik bir Yönetim Özeti** hazırlayınız.

Teknik detaylardan kaçınınız.

Yönetimin anlayabileceği dil kullanınız.

💡 Denetçi İpucu

Bu çalışmada sadece prosedürlere odaklanmanız yeterli değildir.

Aşağıdaki alanları birlikte değerlendirmeniz beklenmektedir:

✅ Kullanıcı yaşam döngüsü yönetimi

✅ Ayrıcalıklı hesap yönetimi

✅ İşten ayrılan personel kontrolleri

✅ Shared Account kullanımı

✅ MFA uygulamaları

✅ Hesap kilitleme mekanizmaları

✅ Parola dayanıklılığı

✅ Hash algoritmalarının güvenliği

✅ Erişim gözden geçirme süreçleri

✅ Görevler ayrılığı (Segregation of Duties)

🏁 Beklenen Çıktı

Bu laboratuvarın sonunda katılımcının;

- Erişim yönetimi denetimi yapabilmesi,
- Kritik güvenlik zafiyetlerini tespit edebilmesi,
- Teknik bulguları iş riskine çevirebilmesi,
- Yönetim özeti hazırlayabilmesi,

beklenmektedir.

🎓 Gerçek hayattaki birçok CISA, CISM, CISSP ve BT Denetim görüşmesinde benzer senaryolarla karşılaşabilirsiniz.